**Luca Danisi** **31-3-2026**

```
Null session + Arp
     Poisoning
```

## 1 - Objective :

Demonstrate how an ARP Poisoning attack works using Ettercap in a controlled lab environment. The goal was to position Kali Linux as a Man-in-the-Middle between a victim machine (Windows 10) and the network gateway (pfSense), intercepting unencrypted network traffic and capturing credentials in cleartext.

🧪 **Our lab environment**

🐉 **Kali Linux**: Attacker
💀 **Windows 10 pro** : web target machine
**Pfsense** : Gateway

All VMs are connected on the same VirtualBox internal network.

## 2 - Tools Used :

- Ettercap 0.8.4 — tool for Man-in-the-Middle attacks and ARP Poisoning
- Wireshark — packet analyzer used to verify ARP traffic and detect the poisoning
- Kali Linux — attacker machine
- Windows 10 Pro — victim machine
- pfSense 2.7.2 — network gateway/router
- VirtualBox — virtualization environment for the lab

## 3 - Results :

1. ARP Poisoning successful — the Windows ARP table showed the gateway (192.168.50.1) mapped to Kali's MAC address (08-00-27-79-33-ba), confirming that Kali had successfully positioned itself as Man-in-the-Middle.
2. Credentials captured in cleartext — Ettercap intercepted login credentials submitted on an HTTP website:
    - URL: http://demo.testfire.net/login.jsp
    - Username: admin
    - Password: admin
3. Attack detected via Wireshark — fake ARP packets were clearly visible in the capture, with the message "duplicate use of 192.168.50.102 detected!", confirming the ARP table poisoning.

## 4 - Issues Encountered During the Test :

1. Misconfigured DNS — Windows had the DNS set to Kali (192.168.50.100) from a previous lab exercise. Since Kali doesn't run a DNS server, no websites were reachable. Fixed by setting the DNS to 8.8.8.8.
2. Test website unavailable — the original exercise website (testphp.vulnweb.com) was offline. Replaced with demo.testfire.net, another HTTP vulnerable site suitable for the test.
3. IP Forwarding disabled — Kali was intercepting packets but not forwarding them, blocking the victim's navigation. Fixed by enabling forwarding with:

   **“echo 1 | sudo tee /proc/sys/net/ipv4/ip_forward”**
4. No real gateway in the lab — initially the internal network had no gateway, making the attack only partial. Fixed by starting pfSense as the network router.

## 5 - Conclusion

The ARP Poisoning attack was successfully executed in a controlled lab environment. The results clearly demonstrate how easy it is for an attacker to position themselves as Man-in-the-Middle on a local network and intercept unencrypted traffic.

The key takeaway is that HTTP provides zero protection — credentials travel in cleartext and anyone on the network can read them. Simply using HTTPS would make the intercepted data completely unreadable.

Wireshark also proved that this type of attack is detectable — fake ARP packets leave clear traces in the network traffic. A SOC analyst could identify it by monitoring ARP table anomalies or using dedicated tools like ARPwatch.

Main lesson: never trust unencrypted connections, and always use encrypted protocols to transmit sensitive data.

**Technical Walkthrough**

**1. Connectivity Check** Verified that the attacker machine (Kali Linux – 192.168.50.100) and the victim machine (Windows 10 Pro – 192.168.50.102) could communicate with each other. Test performed via PING.

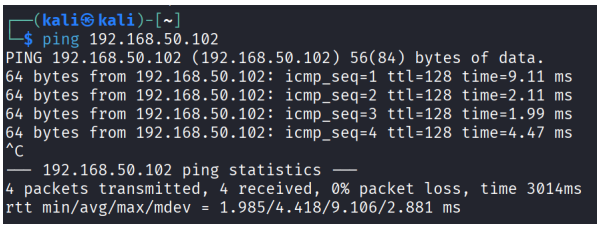
**2. Launching Ettercap** From the Kali Linux terminal, launched Ettercap in GUI mode with the command `sudo ettercap -G`, then started a host scan to discover all devices on the network.

**3. Target Identification & ARP Poisoning** After the scan, identified the two targets: Windows (192.168.50.102 – MAC 08:00:27:16:CC:21) and pfSense (192.168.50.1 – MAC 08:00:27:B2:2F:C6). Added them to Target 1 and Target 2, then launched the ARP Poisoning attack with "Sniff remote connections" enabled.

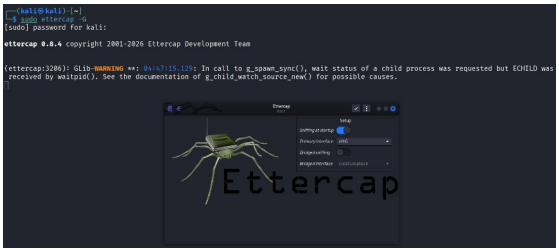
**4. Vulnerability Exposed** On the Windows machine, ran `arp -a` and confirmed that the gateway (192.168.50.1) and Kali (192.168.50.100) shared the same MAC address — meaning all traffic was now passing through the attacker. Opened an HTTP login page on the Windows browser: Wireshark detected the duplicate MAC address anomaly, while Ettercap captured the login credentials in cleartext.

# Screenshot

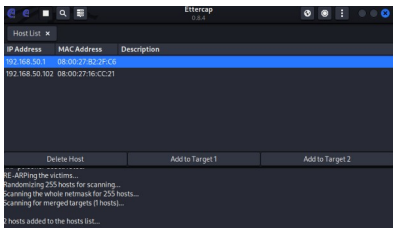
## Figure 1 – Connectivity check between machines via Ping

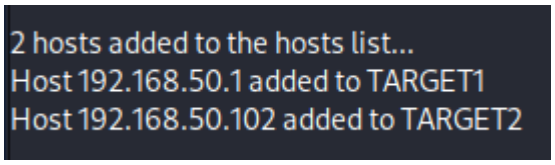



## Figure 2 – Launching Ettercap on Kali Linux

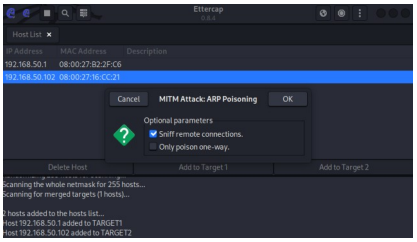


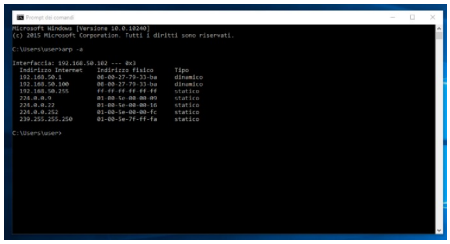

## Figure 3 – Network host scan & target selection



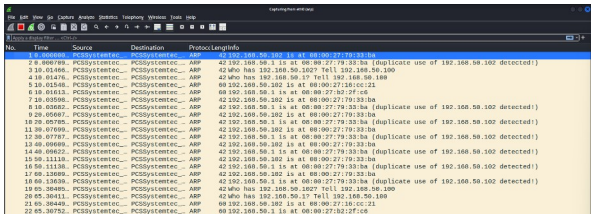




## Figure 4 – ARP Poisoning attack & verification via arp -a on Windows



## Figure 5 – Attack detected by Wireshark

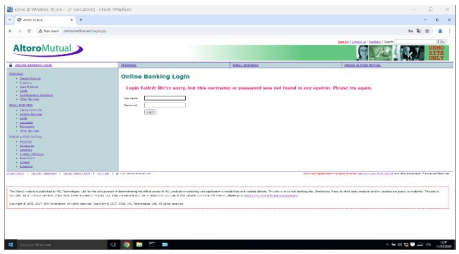


```
[Duplicate IP address detected for 192.168.50.1 (08:00:27:79:33:ba) - also in use by 08:00:27:b2:2f:c6 (frame 7)]
[Duplicate IP address detected for 192.168.50.102 (08:00:27:16:cc:21) - also in use by 08:00:27:79:33:ba (frame 7)]
```

## Figura 6 – Attack detected by Ettercap

```
GROUP 1 : 192.168.50.1 08:00:27:B2:2F:C6

GROUP 2 : 192.168.50.102 08:00:27:16:CC:21
HTTP : 65.61.137.117:80 -> USER: admin  PASS:  INFO: http://demo.testfire.net/login.jsp
CONTENT: uid=admin&passw=admin&btnSubmit=Login
```



End